

CSP: style-src unsafe-inline (Systemic)

Assessment Identifier: **WS-DYN-03** | Assessment Type: **Dynamic** | Date: **September 08, 2026**

Severity: MEDIUM	CVSS: 5.0	CWE: CWE-693
OWASP: A05:2021 - Security Misconfiguration	WASC ID: 15	Confidence: High
Target / Component: Main Dashboard Interface	Affected URL: https://www.worldmonitor.app/dashboard	Parameter: content-security-policy

1. Description

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. The application's Content Security Policy includes 'unsafe-inline' within the style-src directive, allowing arbitrary inline style sheets and inline style attributes to execute.

2. Steps to Reproduce

1. Send an HTTP GET request to https://www.worldmonitor.app/dashboard.
2. Inspect the HTTP response headers returned by the web server.
3. Locate the content-security-policy header.
4. Verify that style-src contains the 'unsafe-inline' directive.

3. Controlled Proof of Concept

HTTP Header Evidence:
content-security-policy: default-src 'self'; connect-src 'self' https: wss: blob: data: https://*.ingest.sentry.io; img-src 'self' data: blob: https;; style-src 'self' 'unsafe-inline'; ...

Verification Check:
Browser permits inline CSS blocks such as <style>body { display: none; }</style> or inline attributes like <div style="background-image: url(...) "> without raising CSP block errors in the console.

4. Business & Security Impact

Allowing 'unsafe-inline' for CSS allows attackers (if an HTML injection point exists) to inject arbitrary CSS styles. This can be abused for UI redressing, web defacement, phishing overlays, or CSS-based data exfiltration (such as abusing background-image: url(...)) or CSS keyframe animations to exfiltrate sensitive values or anti-CSRF tokens token-by-token).

5. Remediation Recommendations

- Primary Fix:** Remove 'unsafe-inline' from the style-src directive and move styling to external stylesheets or nonce-protected tags.
1. Remove 'unsafe-inline' from the style-src directive.
 2. Move all inline styles into external CSS files served from the same domain or trusted origins.
 3. If dynamic inline styles are necessary, implement cryptographically secure nonces (e.g., style-src 'nonce-rAnd0m123') or hashes (e.g., style-src 'sha256-...').

4. Ensure the web server, application server, or load balancer is configured to serve the updated CSP header across all environment instances.

6. Evidence & Validation

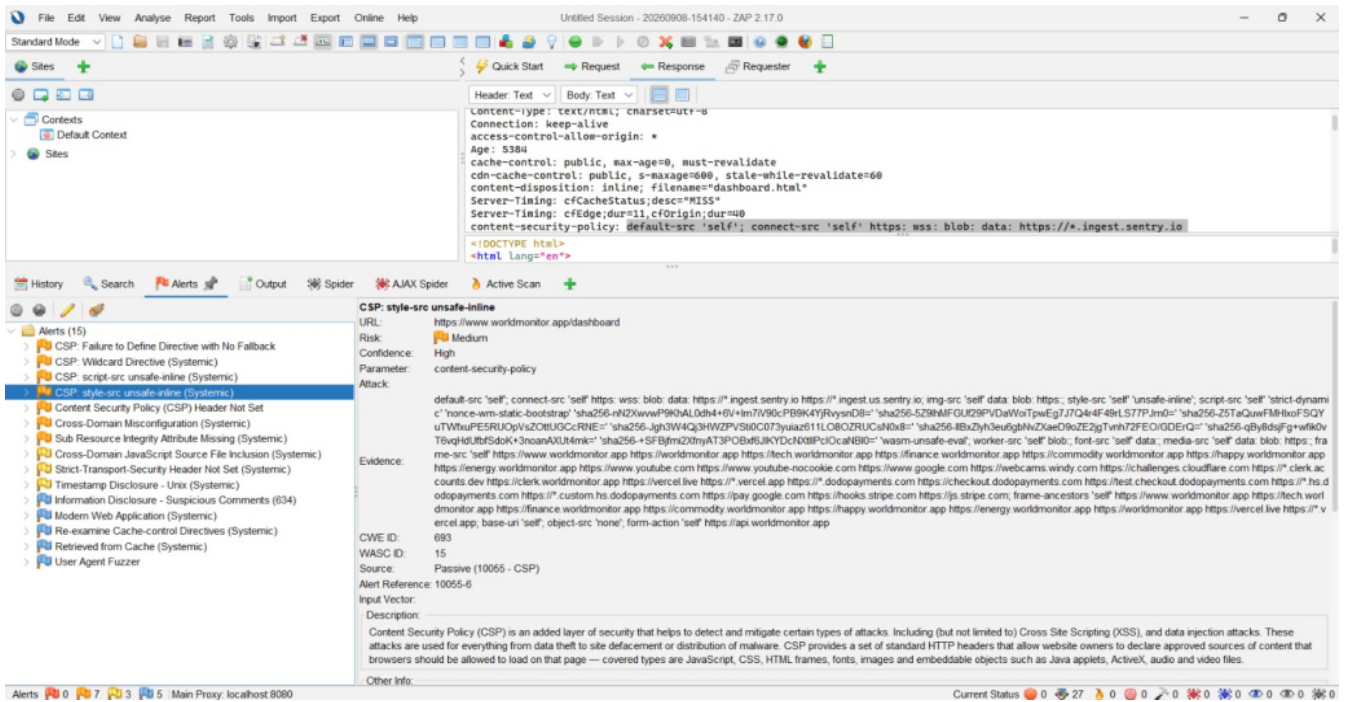


Figure 1: Matched Proof-of-Concept Screenshot for Vulnerability #3 (3/poc-1.png)

Authorization & Safety Compliance: This security assessment was conducted strictly under authorized parameters in accordance with ethical hacking standards. All validations and safe proof-of-concept tests were non-destructive. No persistent modifications or sensitive data exfiltration occurred.